Prepared by: Hasina Rindra
Course: SOC Practical / Week 4
Date: 30 March 2026

Week 4 - Capstone Project: Comprehensive SOC Incident Response

1. Objective

Execute a complete SOC incident response lifecycle: simulate a multi-stage attack, detect and triage alerts, contain the threat, conduct root cause analysis, calculate performance metrics, and produce executive-level reporting.

---

2. Tools Used

Metasploit Framework — Attack simulation including Nmap scanning, SMB/SSH brute force, and payload generation
MITRE Caldera 5.3.0 — Automated adversary emulation with Sandcat agent deployment
Wazuh 4.x — SIEM for detection, alert triage, MITRE ATT&CK mapping, and threat hunting
iptables — Network containment via firewall rules for attacker IP blocking
McAfee Endpoint Protection — Endpoint antivirus detection
Draw.io — Fishbone diagram for root cause analysis

---

3. Lab Environment

Machine	Role	IP	OS
Kali Linux VM	Attacker / C2 Server	192.168.56.102	Kali Linux 2026
Windows 11 Host	Target (Wazuh Agent)	192.168.56.1	Windows 11
Ubuntu VM	Wazuh Server / Defender	192.168.56.105	Ubuntu 24.04

---

4. Attack Simulation

4.1 Reconnaissance (T1046 — Network Service Scanning)

Performed Nmap aggressive scan against the Windows 11 target to identify open ports and services.

Command:

```
sudo nmap -sV -O -A 192.168.56.1
```

Results:

Port	State	Service	Version
22	Open	SSH	OpenSSH for Windows 9.5
135	Open	MSRPC	Microsoft Windows RPC
139	Open	NetBIOS-SSN	Microsoft Windows netbios
445	Open	Microsoft-DS	SMB 3.1.1

Host identified as STIFLER running Windows 11 21H2 with 96% confidence.

4.2 Brute Force Attack (T1110 — Brute Force)

Executed SMB and SSH brute force attacks using Metasploit auxiliary modules with standard wordlists. The SMB attack ran for approximately 5 minutes and the SSH attack for 2-3 minutes, generating hundreds of failed login attempts recorded as Windows Event ID 4625.

4.3 Payload Delivery (T1105 — Ingress Tool Transfer)

Generated a Meterpreter reverse TCP payload (7,680 bytes) disguised as update.exe. Hosted on a Python HTTP server on port 8080. Delivered to the Windows target via PowerShell Invoke-WebRequest command, simulating a phishing-based download scenario. Chrome browser flagged the download as unsafe.

4.4 Execution Attempt (T1204 — User Execution)

Attempted execution of the payload on Windows 11. McAfee endpoint protection detected and blocked the malicious binary, displaying the alert: "We just stopped a threat. A malicious app was detected and automatically blocked from running." The file was quarantined.

4.5 Adversary Emulation via Caldera (T1033, T1082, T1016, T1057, T1083, T1078)

Deployed MITRE Caldera Sandcat agent on Windows 11 and executed an automated adversary operation using a discovery-focused profile. Six TTPs were executed autonomously.

Timestamp	Source IP	Alert Description	MITRE Technique
2026-04-05 17:12:00 IST	192.168.56.102	Active user discovery	T1033
2026-04-05 17:12:15 IST	192.168.56.102	System info enumeration	T1082
2026-04-05 17:12:30 IST	192.168.56.102	Network config discovery	T1016
2026-04-05 17:12:45 IST	192.168.56.102	Process listing	T1057
2026-04-05 17:13:00 IST	192.168.56.102	File/directory scanning	T1083
2026-04-05 17:13:15 IST	192.168.56.102	Account enumeration	T1078

---

5. Detection and Triage

5.1 Wazuh Alert Summary

The Wazuh agent on Windows 11 buffered events locally while the server was offline and forwarded them upon reconnection.

Severity	Count	Rule Level
Critical	0	15+
High	0	12-14

Severity	Count	Rule Level
Medium	22	7-11
Low	8,027	0-6

Total MITRE ATT&CK mapped events: 2,053

5.2 Triage Record

Alert ID	Description	Source IP	Priority	MITRE Technique	Status
001	Multiple auth failures	192.168.56.102	Medium	T1110	Triaged
002	SSH brute force	192.168.56.102	Medium	T1110.001	Triaged
003	PowerShell download	192.168.56.1	Medium	T1059.001	Triaged
004	Malware blocked (McAfee)	192.168.56.1	High	T1204	Resolved
005	Valid accounts misuse	192.168.56.1	Medium	T1078	Triaged

5.3 Threat Validation

The malicious payload was validated via McAfee endpoint detection. The AV engine identified the file as a known threat and quarantined it automatically. VirusTotal lookup was not applicable for the private lab IP (192.168.56.102).

---

6. Response and Containment

6.1 Attacker IP Blocked

Applied iptables firewall rule on the Ubuntu/Wazuh server to block all traffic from the attacker:
Command: sudo iptables -A INPUT -s 192.168.56.102 -j DROP
Verified with: sudo iptables -L -n --line-numbers

6.2 Endpoint Cleanup

Killed the Caldera Sandcat agent process on Windows 11. Removed the agent binary from C:\Users\Public\. The malicious payload (update.exe) had already been quarantined by McAfee.

6.3 SOAR Automation (Wazuh Active Response)

While a full SOAR platform was not deployed due to resource constraints, the response workflow was documented as a playbook:

Playbook Step	Status	Notes
Detect brute force	Success	Wazuh rule triggered on 5+ failed logins
Alert SOC analyst	Success	Alert visible in Wazuh dashboard
Block attacker IP	Success	iptables rule applied on Ubuntu server
Document incident	Success	Case documented with timestamps

---

7. Post-Incident Analysis

7.1 Root Cause Analysis — 5 Whys Method

#	Question	Answer
1	Why was the host attacked?	SSH and SMB services exposed on the network
2	Why were services exposed?	Default configuration with no network segmentation
3	Why was there no segmentation?	Lab environment lacks firewall rules
4	Why were no firewall rules in place?	No hardening policy applied to the endpoint
5	Why was hardening not applied?	No security baseline or CIS benchmark implemented

Root Cause: Lack of endpoint hardening and network segmentation allowed the attacker to access and brute force exposed services.

7.2 Fishbone Diagram

Created in Draw.io with the following cause categories:

People: SOC analyst response time dependent on manual alert review
Process: No automated containment playbook; manual IP blocking required
Technology: Default Wazuh rules generate 87% false positive rate; no Sysmon integration for process-level visibility
Environment: Lab setup with flat network topology; all machines on the same subnet

8. Metrics Reporting

Metric	Value	Industry Benchmark	Assessment
MTTD	42 minutes	24-48 hours	Excellent
MTTR	82 minutes	4-8 hours	Good
Dwell Time	117 minutes	21 days (median)	Excellent
False Positive Rate	87%	< 50%	Needs Work
Total Alerts	8,049	—	—
MITRE-Mapped Alerts	2,053	—	—

9. Incident Report (SANS Template — 300 words)

Executive Summary

On April 5, 2026, a controlled adversary emulation exercise was conducted against the SOC lab environment. A multi-stage attack was launched from Kali Linux (192.168.56.102) targeting a Windows 11 endpoint (192.168.56.1) monitored by a Wazuh agent.

The attack chain included network reconnaissance via Nmap, SMB and SSH brute force attacks generating over 1,000 failed login attempts, malware delivery via a disguised Meterpreter payload, and automated adversary TTP execution using MITRE Caldera. McAfee endpoint protection successfully blocked the malicious payload, and Wazuh SIEM detected 2,053 events mapped to the MITRE ATT&CK framework.

Timeline

Time (IST)	Event
15:33	Nmap reconnaissance initiated
15:38	SMB brute force attack started
15:45	SSH brute force attack started
16:04	Malicious payload delivered via HTTP
16:08	McAfee blocked payload execution
16:22	Wazuh alerts reviewed — 1,074 auth failures
17:12	Caldera adversary emulation executed
17:30	Attacker IP blocked via iptables
17:45	Incident closed, cleanup completed

Root Cause Analysis

The attack reached the target due to exposed SSH and SMB services with no network segmentation. Default Wazuh rules detected brute force activity but produced an 87% false positive rate, indicating significant need for rule tuning and baseline establishment.

Recommendations

1. Implement Sysmon integration with Wazuh for process-level monitoring (Event IDs 1, 3, 7, 11)
2. Tune Wazuh detection rules to reduce the false positive rate by at least 50%
3. Apply network segmentation to isolate critical endpoints behind firewall rules
4. Configure Wazuh active response for automated IP blocking after 10 or more failed login attempts
5. Schedule quarterly Caldera emulation exercises to validate detection improvements

---

10. Stakeholder Briefing (150 words)

Incident Summary for Executive Leadership

On April 5, our security team conducted a planned adversary simulation to test our defenses. An attacker machine attempted to compromise our Windows workstation using password guessing, malware delivery, and automated attack tools.

What worked:
Our antivirus (McAfee) successfully blocked the malware. Our monitoring system (Wazuh) detected over 1,000 suspicious login attempts and mapped them to known attack patterns. Detection time was 42 minutes, well below the industry average of 24 hours.

What needs improvement: Our monitoring system generated many false alarms (87% false positive rate), which could slow analyst response during a real incident. Additionally, automated threat blocking is not yet configured.

Next steps:

We recommend investing in three areas:

(1) automated threat blocking to reduce response time,

(2) monitoring rule refinement to reduce false alarms by 50%, and

(3) quarterly security exercises to continuously validate our defenses.

Screenshots

15_Nmap_Scan_Results: Nmap aggressive scan showing open ports 22, 135, 139, 445 on Windows 11 target

16_SMB_Brute_Force: Metasploit smb_login module configured and running against 192.168.56.1

17_SSH_Brute_Force: Metasploit ssh_login module running brute force attack against Windows 11

18_Payload_Generation: msfvenom creating update.exe Meterpreter reverse TCP payload (7680 bytes)

19_Payload_Download_Blocked: Chrome browser blocking update.exe download as unsafe

20_PowerShell_Download: Invoke-WebRequest successfully downloading update.exe to Windows Downloads folder

21_McAfee_Detection: McAfee blocking payload execution with "We just stopped a threat" alert

22_Netstat_Connections: PowerShell netstat output showing active ESTABLISHED connections during attack

23_Iptables_Block: Ubuntu iptables rule showing DROP for attacker IP 192.168.56.102